

HealthTrack AI

Synthèse du projet et des innovations ajoutées - IA réelle & sécurité

François Zogbelemou

1. Le projet en bref

HealthTrack AI est une plateforme mobile de suivi santé préventif pensée pour le contexte marocain et régional : elle exploite les capteurs du smartphone, la saisie manuelle et l'import de documents médicaux, sans objet connecté. Trois rôles - patient, médecin, administrateur - et une architecture en microservices : application **React Native/Expo**, backend **Spring Boot (Java 21)**, microservice **IA FastAPI (Python)**, bases **MongoDB / Redis** et stockage **MinIO**, le tout orchestré par Docker.

Point de départ honnête : le socle applicatif existait, mais les fonctions d'IA n'étaient pas implémentées (résultats simulés) et plusieurs failles de sécurité étaient présentes. Le travail décrit ici transforme ces deux volets en fonctionnalités réelles.

2. Innovation n°1 - une IA réellement entraînée

Remplacement des résultats simulés par un **modèle de Machine Learning entraîné** sur un jeu de données public de 70 000 patients (Cardiovascular Disease, Kaggle). Après nettoyage des valeurs aberrantes (68 592 lignes retenues), trois modèles ont été comparés ; le **Gradient Boosting** a été retenu.

Modèle	Exactitude	Rappel	AUC
Régression logistique	0,728	0,677	0,793
Random Forest	0,732	0,677	0,798
Gradient Boosting (retenu)	0,735	0,694	0,801

Intégration et bonnes pratiques :

- Le modèle est servi par le microservice IA via **POST /analyze/predict** et renvoie un niveau de risque (STABLE / AMBER / RED), une probabilité et les facteurs aggravants.
- Le backend Spring appelle ce service, enregistre le résultat en statut **PENDING** (validation médicale requise) et retombe sur une analyse de repli si l'IA est indisponible.
- **Garde-fous** : bornes physiologiques sur les entrées ; priorité donnée au **rappel** (ne pas manquer un patient à risque) ; versions de bibliothèques figées pour la reproductibilité.
- **Transparence** : le résultat n'est jamais un diagnostic automatique - il est soumis à la validation d'un médecin.

3. Innovation n°2 - la sécurité d'une application de santé

a. Correction des failles identifiées (réalisé)

- Élévation de privilèges à l'inscription : le rôle est désormais forcé à PATIENT côté serveur.
- Fuite des mots de passe hachés dans les réponses de l'API : masqués.
- Accès d'un médecin aux dossiers de patients non assignés : bloqué (403).
- Écrasement de dossier via identifiant fourni, exposition des bases sur le réseau, gestion d'erreurs divulguant des détails internes : corrigés.

b. Journal d'accès infalsifiable (réalisé)

Chaque accès sensible (lecture de dossier, analyse IA, messagerie, assignation) est inscrit dans un registre **chaîné par hash** : chaque entrée contient le hash de la précédente. Toute modification ou suppression a posteriori casse la chaîne et devient **déTECTABLE**. Le patient peut consulter lui-même qui a accédé à son dossier - un renversement au service de l'usager, aligné sur la loi 09-08 (CNDP).

c. Détection d'accès anormaux - UEBA (réalisé, phase 1)

Analyse du journal pour repérer les comportements suspects (rafale d'accès, nombre de patients distincts, accès nocturnes), avec un score motivé. Démarche honnête : **règles statistiques aujourd'hui**, évolution vers un modèle non supervisé (Isolation Forest) une fois un historique réel accumulé.

d. Accès « bris de glace » (proposé)

Pour concilier confidentialité et urgence médicale : un médecin non assigné peut accéder à un dossier en urgence en justifiant l'accès, qui est alors marqué haute sévérité, déclenche une alerte et une revue a posteriori. Motif de sécurité hospitalier reconnu.

4. Limites assumées et perspectives

- Journal chaîné : registre centralisé - un administrateur du serveur pourrait le recalculer. Parade prévue : **ancrage externe** périodique du dernier hash.
- Autres pistes : chiffrement des champs sensibles au repos, TLS mutuel entre services, validation médicale des résultats IA (écran médecin).
- Le modèle requiert des données (sexe, taille, poids, cholestérol) via un formulaire dédié ; enrichir le profil patient permettrait de le pré-remplir.

Document de synthèse - projet HealthTrack AI. « Réalisé » = codé et vérifié ; « proposé » = conçu, à implémenter. Les métriques proviennent de l'évaluation sur jeu de test (20 %).